KYRO — Student Data Privacy & Compliance Overview

Knowledge Yielding Resource Optimizer · How KYRO safeguards student data *Version 2.0 — August 2026 (supersedes v1.0, July 2026)*

1. Purpose

This document describes the technical and organizational safeguards KYRO implements for student data, and states honestly which privacy laws bind KYRO's service to its customers and how KYRO meets them. It is intended for school administrators, business officers, boards, diocesan offices, and IT/security reviewers evaluating KYRO.

> **Built to FERPA standards:** KYRO is **FERPA-aligned by design and FERPA-equivalent by contract** (Section 2). There is no government "FERPA certification" and no vendor can truthfully claim to be "FERPA-certified" or "FERPA-compliant" as a legal status; this document describes KYRO's actual controls. It is a good-faith description, not a legal opinion.

2. FERPA — the honest framing

FERPA (20 U.S.C. § 1232g; 34 CFR Part 99) applies to educational agencies and institutions that receive funding under programs administered by the U.S. Department of Education. Most private and faith-based K-12 schools do not receive such funds and, in the Department's own words, are **not directly subject to FERPA** — and neither, in that case, is KYRO.

KYRO's posture is therefore **"FERPA-equivalent by contract"**: regardless of whether FERPA formally binds a customer, KYRO contractually behaves as a **"school official" under 34 CFR § 99.31(a)(1)(i)(B)** would have to:

1. It performs an institutional service the school would otherwise use its own employees for;
2. The **school owns and controls** its data — use and maintenance are under the school's direct control;
3. KYRO uses education records **only** to provide the contracted service — never for advertising, profiling, sale, or training third-party AI models; and
4. KYRO does **not re-disclose** records (the § 99.33 no-redisclosure rule), except as the school directs or the agreement permits.

Customer screening: a small number of private schools hold direct U.S. Department of Education grants, which *does* bring FERPA into direct effect. KYRO's onboarding asks about this, and for such customers (and for public-school or publicly funded pre-K deals) KYRO maintains an **NDPA-style data protection addendum** aligned with state student-privacy contract laws (e.g., New York Ed. Law § 2-d, Connecticut, Colorado, Utah, Virginia, Florida).

3. COPPA — why it does not apply

COPPA does not apply to KYRO because no personal information is collected online from children; students do not use the service. Every COPPA duty keys to personal information "collected online **from** a child" — KYRO's users are school staff and administrators, and student data arrives from the school itself (its SIS export, its business office), which the FTC's own COPPA FAQ confirms is outside the Rule.

KYRO does **not** claim to be "COPPA-compliant" — compliance language would imply the Rule applies. Instead KYRO maintains an **internal product tripwire**: *no student-facing surface, ever, without a full COPPA (as amended, 2025) review first.* Any feature that would let a student log in, submit information, or be tracked online flips the entire Rule on instantly; the product rule is that such a feature does not ship without that review.

4. State student-privacy laws — the ones that DO bind

Vendor-facing state student-privacy statutes apply to KYRO directly wherever it serves schools in those states, and KYRO treats the strictest common denominator as its **national floor**:

- **California SOPIPA** (Bus. & Prof. Code § 22584 et seq., as amended by AB 801, effective Jan 1 2025 — including the parent/guardian-initiated deletion right, which KYRO honors as routed through the school);
- **Illinois SOPPA** (105 ILCS 85 — which expressly includes private and nonpublic schools in its definition of "school", requires breach notice to affected schools **within 30 days**, and requires a **public data-practices disclosure** — KYRO's public Privacy Policy page is that disclosure);
- **Washington RCW 28A.604** (read conservatively as applying).

The common duty set, and how KYRO meets each:

Duty	KYRO
No targeted advertising, no profiling for non-educational purposes, no sale of student data	KYRO has no advertising, no profiling, no data sale — contractually and architecturally (there is no ad or tracking integration in the product)
Disclosure only for enumerated purposes	Data leaves KYRO only to the sub-processors in Section 9, each for a named service function
Reasonable security	Section 6 (TLS everywhere, KMS at rest, tenant isolation, WAF, private network, audit logging)
Deletion on school request	School-, organization- and record-level deletion, including hard-delete of individual student rows; parent-initiated deletion (AB 801) honored when routed through the school
Breach notice	KYRO commits to notifying affected schools **within 30 days** of determining a breach of student data (IL SOPPA's clock; contractual NDPA terms may be shorter, e.g. 72 hours, where agreed)
Public data-practices disclosure (IL)	The KYRO Privacy Policy at `/privacy` publicly states what is collected, why, and with whom it is shared

5. Data minimization — what KYRO actually stores

KYRO's core product operates on institution-level financial and operational data — trial balances, statements, budgets, enrollment counts, aggregate assessment results. Two modules can additionally hold **student-level rows**, and this document describes them plainly rather than claiming otherwise:

- The **enrollment roster register** (optional, enrollment module) stores a deliberately **data-minimal student record**: name, grade, coarse demographics (gender/race/ethnicity as recorded by the school), date of birth, enrollment status and dates, three **coarse boolean** support flags (IEP / 504 / ELL), an optional external SIS identifier, and free-text notes the school chooses to enter. It stores **no** Social Security numbers, no addresses, no family contact information, no medical or disciplinary records, no grades-as-transcript.
- The **academics module** stores assessment results keyed to the same register.

The one-door rule: student identity is readable through exactly one surface — the register's own routes, behind the authenticated, school-scoped, role-gated API. That door is open to a school's **owners and business managers only**: the read-only "viewer" role (the board / leadership lens) sees the roster solely as suppressed counts, never as named records with their support-plan flags — the same line the Academics register draws for named results. KYRO enforces it on the API and logs access. Every other surface in the

product — dashboards, analytics, the org roll-up, briefings, exports to the AI assistant — receives **counts only, never a name**, enforced structurally (build-gate tests fail if any assistant-directory code can reach the student table).

Hard deletion is honored: deleting a student removes the row itself, not a flag on it.

6. Technical safeguards

6.1 Encryption in transit — end-to-end TLS

All data moving to, from, and within KYRO is encrypted with TLS:

Segment	Protection
User's browser → KYRO edge (CloudFront)	TLS 1.3 (minimum TLS 1.2 enforced), managed certificate
Edge → application load balancer	HTTPS-only
Load balancer → application container	**HTTPS** (encrypted inside the private network)
Application → database	TLS **required** (`sslmode=require` , server-enforced `force_ssl`)
Application → storage & AWS services	HTTPS

There is no plaintext hop anywhere in the request path — encryption is **end-to-end**.

6.2 Encryption at rest

All stored data is encrypted at rest with **AWS KMS customer-managed keys (CMKs)** with automatic key rotation:

- **Database** (financial and operational data, including the roster register) — KMS-encrypted; automated encrypted backups with point-in-time recovery; never publicly accessible.
- **Document storage** — server-side encryption with a KMS CMK; a bucket policy **denies any non-TLS request**; all public access is blocked.
- **Secrets** (application credentials) — stored in a managed secrets vault, KMS-encrypted, injected into the application at runtime (never written to disk or source control).

6.3 Access control & tenant isolation

- **Authentication**: password credentials are stored only as salted hashes; session tokens are short-lived; TOTP multi-factor authentication is available; password-reset codes are cryptographically random and single-use.

- **Role-based access**: users see only the schools and modules they are entitled to; owner/accountant/viewer roles gate sensitive actions; the roster register is additionally gated as in Section 5.
- **Tenant isolation**: every request is scoped to the caller's school/organization; a request for another tenant's data is **rejected (HTTP 403)**. This is enforced server-side and verified by automated tests.
- **Least privilege**: the application's cloud identity can access only its own resources; human administrative credentials are separated from application credentials.

6.4 Network isolation & perimeter

- The application runs in **private subnets** with no public IP address; the database is unreachable from the internet.
- A **Web Application Firewall (WAF)** with managed rule sets and per-IP rate limiting protects the public edge.
- Inbound access to the application is restricted to the load balancer; outbound access is limited to the services the platform requires.

6.5 Audit logging & monitoring

- **Infrastructure audit**: AWS CloudTrail records control-plane activity across the account.
- **Application audit**: security-relevant events (logins, record changes, deletions, imports, data-erasure actions) are recorded with actor, action, and timestamp. Roster audit entries record **counts, never names**.

7. De-identification & small-cell suppression (the methodology)

Aggregate figures that could identify a student are suppressed following the approach recommended by the U.S. Department of Education's **Privacy Technical Assistance Center (PTAC)** disclosure-avoidance guidance and NIST de-identification practice (NIST IR 8053):

- Every attribute-coupled count (a demographic cell, a status cell, a support-flag count) smaller than the **minimum cell size of n = 5** is withheld before it leaves the server. The suppressed value is structurally absent — the response carries a `suppressed` marker with **no value field at all**, so no client, export, or AI answer can quote it.
- **Complementary suppression** is applied: when hiding one small cell would let it be re-derived by subtracting the visible cells from a published total, a companion cell is suppressed with it. Headline KPI figures that restate a suppressed cell (for example a "waitlist" tile beside a suppressed waitlist count) follow the same suppression decision in

lockstep, so the same number can never be hidden in one place and shown in another. The honest residual limit, stated plainly: complementary suppression protects each individual cell, not the **combined size** of the suppressed group — a reader can still infer that two withheld cells together account for the remainder of a published total, which is the standard, accepted behavior of this technique.

- Whole-school totals and grade-level headcounts are treated as directory-style institutional facts and are not suppressed — a deliberate, documented line. That line holds only while no attribute is in play: the moment a query filters by status, demographics, support flags, age band, or a name search, every returned count — the filtered total and the per-grade counts included — is an attribute-coupled figure and takes the same n = 5 floor with complementary handling.
- **Labels and bounds, not only sums** (review round 6). On every filtered view a withheld figure carries one label — "withheld" — whatever its size, zeros included: when the same column is hidden in every grade, per-grade "<5" labels could be counted against the published school-wide total. Companion choices account for published column totals and for the school-wide "<5" labels (each hidden cell must still be able to take any value from 1 to 4), and a filtered total is withheld when its group's statuses cannot be protected beside it. The protections are tested by two attackers that hold every published view at once: a linear one (exact subtraction across views) and an integer one that also uses the labels as bounds.
- **Structural knowledge.** Age follows grade, so age bands are withheld whenever, beside the grade counts, any grade × age-band cell would be small (a few pre-K students already five, say). Accepted and stated limit: a reader who knows that a student recorded as Hispanic or Latino by race is also Hispanic by ethnicity can combine that with the race and ethnicity counts.
- n = 5 is a defensible floor for KYRO's context: these are **staff-facing internal analytics** for the school's own personnel, not public reporting (where the recognized convention is a higher floor, commonly n < 10 suppressed). The same n = 5 floor is applied uniformly across enrollment analytics, assessment analytics, the REST aggregation endpoints, and everything the AI assistant can read.

8. Artificial-intelligence privacy — the actual architecture

KYRO's AI assistant (internal codename "Penny") and written insights use large language models. The provider architecture, stated plainly:

- **Production default: Amazon Bedrock inside KYRO's own AWS account.** When a Bedrock model is configured (the production deployment), prompts are processed in-account by AWS; the model provider does not receive data for training and prompt traffic does not leave KYRO's AWS account. Spoken narration in this mode uses in-account Amazon Polly.

- **Alternate paths exist and are guarded, not denied.** The codebase also supports **OpenRouter** (routing to Anthropic Claude) and the **direct Anthropic API** (insight fallback). When these paths are used, every OpenRouter request carries **per-request zero-data-retention flags** (`provider: { data_collection: "deny", zdr: true }`), restricting routing to endpoints that neither store nor train on prompts; requests fail rather than silently fall back to a retaining endpoint. Account-level ZDR enforcement and training opt-outs are additionally maintained as an **operations requirement** on the OpenRouter account, so a misconfigured request cannot widen retention. Anthropic does not use API traffic for training by default.
- **FERPA_MODE redaction (on by default)**: a request-scoped redaction layer tokenizes known identifiers (party/family names, emails, student references) in tool results before they reach any model and restores them only in the answer shown to the authenticated caller; emails and SSN-shaped strings in user-typed chat text are masked before egress. Honest limit: a free-form name typed by a user is not a registered identifier and is not detectable by this layer — the model is instructed never to propagate such names, and the counts-only tool architecture keeps names out of what the assistant reads.
- **Documents**: uploaded PDFs and images are **never sent to the model** under FERPA_MODE (they may be filed to document storage); spreadsheets are reduced to small, tokenized digests (at most ~12 rows) before any model sees them.
- **Chat is not stored server-side.** Conversation history lives in the user's browser session and is re-sent per request; KYRO keeps no server-side transcript store and does not log prompt or response payloads.
- **Spoken audio**: when a school opts into ElevenLabs voice (instead of in-account Polly), the spoken text is scrubbed before egress — emails/SSN-shaped strings masked and internal placeholder tokens stripped. Honest limit: text a user explicitly asks the assistant to speak can still reach the TTS provider; the mitigations are the scrub, the counts-only architecture upstream, and the account-level ElevenLabs training/data-sharing opt-out (an operations requirement).

9. Sub-processors — who receives what

Sub-processor	Service	What it actually receives
Amazon Web Services (US)	Hosting, database, document storage, KMS, Bedrock models, Polly voice	All Customer Data categories, encrypted in transit and at rest, inside KYRO's own account
Anthropic (US)	Language model behind the KYRO assistant/insights (via OpenRouter or direct API, when not on Bedrock)	Redacted, tokenized prompts and aggregate figures; no documents; not used for training
OpenRouter (US)	Model routing to Anthropic (non-Bedrock path)	The same redacted prompts, sent with per-request zero-data-retention flags; account-level ZDR/no-training enforcement maintained
ElevenLabs (US)	Optional spoken narration	Scrubbed spoken text only (emails/SSNs masked, tokens stripped); account-level training opt-out maintained
Intuit / QuickBooks (US)	Accounting sync, at the school's election	**Nothing is sent** — KYRO reads from QuickBooks; no student data is involved in either direction
Stripe (US)	Subscription billing	Billing contact and payment details only; no school operational or student data
Brevo (EU)	Transactional email (invites, alerts, scheduled reports)	Recipient addresses and aggregate notification text; no student-level data

10. Data retention & deletion

- **Chat**: never stored server-side (Section 8).
- **Audit log**: retention is configurable via `AUDIT_RETENTION_DAYS` (default: retained until the school configures a window; > 0 trims entries older than N days on a schedule).
- **Deletion / right to erasure**: KYRO provides record-, account-, school-, and organization-level deletion. Deletion runs as an atomic transaction that removes the associated records **and** purges related documents from storage, and is recorded in the audit log. Deletion on school request — including AB 801 parent/guardian-initiated deletion routed through the school — is honored; contractual deletion windows (e.g., NDPA-style 60-day deletion after termination) are supported.
- **Retained roster originals**: when a roster file is imported, the original file is kept for provenance — it is the evidence of which file produced which numbers, reachable only through the Enrollment page's role-gated import history (never through the general document list, search, or viewer download routes). Removing an import entry deletes its

retained file along with it (the file is deleted first; if that deletion fails, the removal is refused rather than leaving an unanchored file behind). **Hard-deleting a student does not rewrite past import files**: the student's row is removed from the register, but a roster file imported before the deletion still contains the names it was imported with. A school that needs a name out of the stored originals removes the corresponding import entries.

- **Termination**: Customer Data remains exportable for thirty days after termination, then is deleted from production and ages out of encrypted backups within the backup retention window.

11. Shared-responsibility model

Responsibility	KYRO	School
Encrypt data in transit & at rest	✓	
Isolate tenants; restrict access; enforce the one-door register rule	✓	
Provide deletion & audit tooling; honor deletion requests	✓	
Suppress small cells in every aggregate surface	✓	
Keep AI redaction + zero-retention controls in place	✓	
Maintain account-level provider opt-outs (OpenRouter ZDR, ElevenLabs no-training)	✓ (operations)	
Designate KYRO a "school official"-equivalent in a written agreement		✓
Configure which roles may open the roster register		✓
Determine legitimate educational interest & who may access		✓
Provide any required annual privacy notification to parents/students		✓
Handle parent/eligible-student access, amendment & deletion requests (KYRO assists)	assists	✓
Follow the school's breach-notification obligations (KYRO notifies the school within 30 days)	assists	✓
Manage school-side user accounts & offboarding		✓

12. Contact

For a data-protection addendum (including the NDPA-style addendum for public or publicly funded deals), a security questionnaire, the sub-processor list, or additional detail, contact **support@ourkyro.com**.

This overview reflects KYRO's production configuration as of August 2026 and is provided for informational purposes. It is not legal advice. Schools should consult their own counsel regarding their privacy obligations.